API Security Risk Analysis Report

Cyber Security Task 3 – 2026

Prepared By: Anaamika KS
Future Interns – Cyber Security Internship

Executive Summary

This report presents a read-only API Security Risk Analysis conducted on a publicly available test API (JSONPlaceholder). The objective of this assessment was to evaluate authentication controls, data exposure levels, and potential security risks associated with publicly accessible API endpoints.

The analysis focuses on identifying security misconfigurations and explaining potential business impacts in a clear and practical manner.

API Overview

API Tested: JSONPlaceholder
Base URL: https://jsonplaceholder.typicode.com

JSONPlaceholder is a public REST API designed for testing and learning. It provides mock user, post, comment, and album data.

Scope of Assessment

The assessment was limited to:

- Read-only API requests (GET endpoints)
- Publicly available endpoints
- Header and response inspection
- No exploitation or abuse attempts

The following were excluded:

- Authentication bypass attempts
- Denial-of-Service testing
- Data manipulation attacks
- Any malicious interaction

Endpoint Analysis

Endpoint Tested: GET /users

URL:

https://jsonplaceholder.typicode.com/users

Observation

The endpoint is publicly accessible and does not require authentication. It returns structured user data including:

- Name
- Email
- Phone number
- Address details
- Company information

Identified Risk 1: Unauthenticated Endpoint

Severity: Medium

Description:
The /users endpoint allows unrestricted public access without authentication or API key validation.

Business Impact:
In real-world SaaS platforms, exposing user data without authentication can lead to:

- Data scraping
- Privacy violations
- Reputation damage
- Regulatory non-compliance (e.g., GDPR)

Recommendation:
Implement authentication mechanisms such as:

- API keys
- OAuth 2.0
- JWT token validation

Access to user-related endpoints should require verified authentication.

Identified Risk 2: Excessive Data Exposure

Severity: Medium

Description:
The API response returns full user objects including address and company details. In production environments, APIs should return only necessary fields.

Business Impact:
Excessive data exposure increases the attack surface and may assist attackers in:

- Social engineering
- Targeted phishing
- Reconnaissance activities

Recommendation:
Apply the principle of least privilege:

- Return only required fields
- Use response filtering
- Mask sensitive attributes

Additional Observations

- No visible rate limiting indicators
- No authentication headers required
- No token validation mechanism observed

In production APIs, absence of rate limiting may allow:

- Automated scraping
- Abuse through repeated requests

Risk Summary Table

Risk Identified	Severity	Impact
Unauthenticated Endpoint	Medium	Data exposure risk
Excessive Data Exposure	Medium	Privacy & compliance risk
Missing Rate Limiting (Observed)	Low–Medium	API abuse potential

Overall Security Assessment

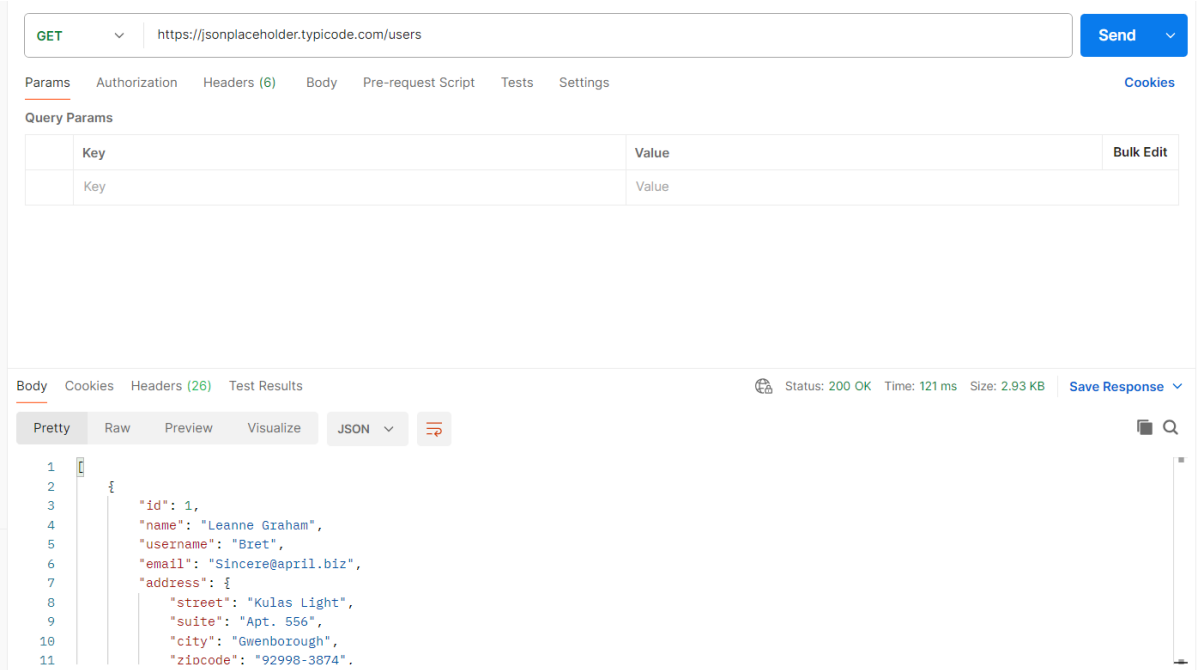
While JSONPlaceholder is intentionally open for testing purposes, similar configurations in real-world SaaS APIs would represent moderate security risks.

APIs should implement:

- Strong authentication controls
- Role-based access control (RBAC)
- Response data minimization
- Rate limiting and monitoring

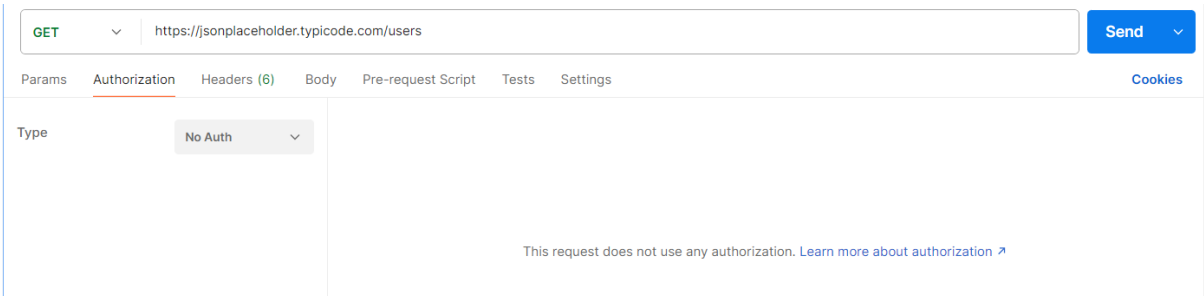
Evidence & Technical Validation

Screenshot 1 – GET /users Request Execution



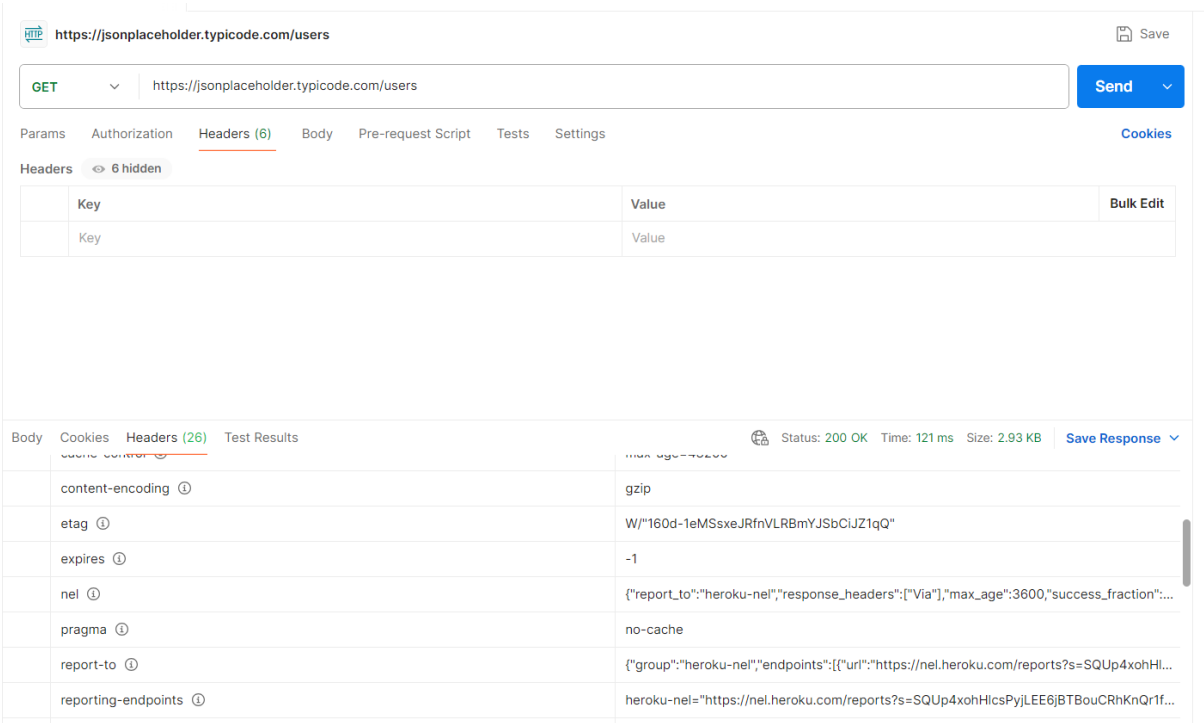
Description:
This screenshot shows the GET request to /users, status code 200 OK, and the JSON response returned without authentication.

Screenshot 2 – Authorization Settings



Description:
This screenshot confirms that the Authorization type is set to "No Auth", indicating that the endpoint does not require authentication.

Screenshot 3 – Response Headers



Description:
This screenshot displays the response headers returned by the API, confirming successful public access.

Conclusion

API security plays a critical role in protecting user data and maintaining trust in SaaS platforms. Even publicly accessible endpoints can introduce risks if authentication and data minimization controls are not properly implemented.

This assessment demonstrates how read-only inspection can identify potential security gaps and provide actionable remediation strategies.